AUDIT REMEDIATION REPORT

SafetyMonitor Audit 조치 분석 보고서

코드베이스 종합 Audit 발견 23건 조치 결과 (산업현장 작업자 생체 모니터링 프로토타입)

작성일 2026-06-03 · **대상** monorepo @ `06.safetymonitor` · **선행** 종합 Audit(MEDIUM 5 / LOW 18)
조치 범위 그룹 A(보안) → C(단일 source·타입) → 정확성 → 테스트 → 위생 · **커밋** 5건 (main ahead 58)
검증 전체 typecheck ✓ · 단위 테스트 38/38 ✓ · dev 런타임 GET / 200 + PII redact live ✓

1. 개요 (Executive Summary)

선행 종합 Audit이 확정한 **23건(MEDIUM 5 / LOW 18)**을 우선순위(공개 터널 전 PII 차단 → 발표 전 단일 source → 정확성 → 테스트 → 위생) 순으로 **전부 조치**했다. 모든 변경은 전체 typecheck·단위 테스트·dev 런타임으로 검증했고, 5개 semantic commit으로 분리해 기록했다.

구분	대상	조치	핵심 효과
🟡 MEDIUM	5	5	PII 미인증 노출·기본 비밀번호·핵심 테스트·tsconfig 플래그·임계 단일 source
⚪ LOW	18	18	정확성 2 · 테스트 2 · dead code 6 · 의존성 1 · 타입 2 · 문서 4 · 세션토큰 1
합계	**23**	**23**	전 항목 적용 + 검증

검증 결과 (모두 통과).

- **typecheck** — schemas · analyzers · dashboard 전체 `tsc --noEmit` exit 0
- **단위 테스트 38/38** — analyzers 15 · schemas 9(신규) · dashboard 14(신규), fail 0
- **dev 런타임** — `GET /` HTTP 200 · `GET /api/mock/vital` 200 `{ "piiRedacted": true }` → M1 PII 차단이 실제 동작함을 라이브 확인

조치 우선순위 그룹

순위	그룹	항목	커밋
A	**공개 터널 전 PII 차단**	M1 GET PII · M2 비밀번호 · L3 세션토큰 (+L9·L18)	`648d942`
C+정확성	단일 source · 타입 강화 · 정확성	M5 · M4(28건) · L1 · L2 · L6/L7/L8 · L17	`fcc74d0`
D	테스트 부채	M3 · L4 · L5 (+러너)	`417cd09`
E	위생 (worker-phone·schemas)	L10 · L11 · L12	`c09c76e`
E	문서 정합 + 기록	L13 · L14 · L15 · L16 + 세션17 기록	`f981265`

2. 그룹 A — 공개 터널 전 PII 차단 (보안)

조치 M1 미인증 GET `/api/mock/vital` PII 유출 차단

BEFORE

GET이 `latestByWorker()`를 그대로 반환 → 보호자 이름·전화, 위·경도가 무인증으로 공개 터널에 노출

AFTER

`redactPii`로 PII 4필드 **기본 제거**. `MOCK_VITAL_EXPOSE_PII=true`로만 신뢰 환경 opt-in. 응답에 `piiRedacted` 플래그

```
const EXPOSE_PII = process.env.MOCK_VITAL_EXPOSE_PII === "true";
function redactPii(s) {
  if (EXPOSE_PII) return s;
  const { guardianName, guardianPhone, latitude, longitude, ...rest } = s;
  return rest;   // 기본: 민감 PII 비노출(fail-safe)
}
```

런타임 검증 — `GET /api/mock/vital → 200, "piiRedacted": true` 확인.

조치 M2 기본 관리자 비밀번호(동작 default) 제거 — fail-closed

BEFORE

`ADMIN_PASSWORD ?? "safety2026"` — 미설정 시 소스에 적힌 비밀번호로 PII export 접근 가능. `.env.example`도 실동작값 출하

AFTER

`?? ""` + 미설정 시 **인증 항상 거부**(경고 로그). `.env.example` 빈 placeholder + 강한 비번 설정 안내

```
const ADMIN_PASSWORD = process.env.ADMIN_PASSWORD ?? "";
export function verifyCredentials(id, password) {
  if (!ADMIN_PASSWORD) { console.warn("...fail-closed..."); return false; }
  return safeEqual(id, ADMIN_ID) && safeEqual(password, ADMIN_PASSWORD);
}
```

조치 L3 세션 토큰을 비밀번호와 분리

BEFORE

토큰 = `base64(id:password)` — 가역(평문 비밀번호), 만료 없음. XSS 시 비밀번호 영구 노출

AFTER

로그인 시 **랜덤 불투명 토큰 + 서버측 8h TTL** 발급 (`createSession`/`validateSession`). 클라이언트·6개 admin 라우트 무변경(하위호환)

+ L9 미사용 `ADMIN_ID_HINT` export 제거 · **+ L18** `catch (error: unknown)`로 전환

3. 그룹 C — 단일 source 복구 + 타입 강화

조치 M5 vital 임계 분류 로직 단일 source 복구

BEFORE

`DemoDashboard.tsx`가 `heartRateStatus/spo2Status/coreTempStatus`를 매직넘버(130/40/110/50, 88/92)로 중복 정의 → THRESHOLDS 변경이 카드 색칠에 전파 안 됨

AFTER

로컬 정의 삭제 후 `lib/severity.ts`(analyzers THRESHOLDS 단일 source)에서 import. **거동 동일**, 임계 단일화

검증 — `severity.test.ts`가 THRESHOLDS 기준 경계(매직넘버 아님)로 8건 통과.

조치 M4 dashboard tsconfig `noUncheckedIndexedAccess` 활성 + 28건 가드

BEFORE

dashboard tsconfig가 base 미상속 → 플래그 누락. 최대 런타임 표면(데모 렌더)에서 배열 인덱스 접근 전부 미검사

AFTER

`noUncheckedIndexedAccess+noImplicitOverride` 활성. 노출된 **28건(10파일)** 미검사 접근을 전부 안전 가드

파일	건수	대표 가드
`app/lib/typhoon.ts`	8	최신 태풍 `head` undefined 가드
`VitalHistoryPanel.tsx`	4	`points[idx]` 가드 후 렌더
`kma.ts / WidgetCarousel / WeatherStrip / WeatherRuleModal / SiteSafetyTables / AdminExportModal / DemoDashboard / weather route`	16	시·도 fallback · 캐러셀 `cur` · 예보 배열 · 정규식 그룹 등

4. 정확성 패치

조치 L1 sticky `latestByWorker` ts 역행 방지 + 순수 함수 추출

BEFORE

삽입 순서 last-writer로 `ts` 무조건 갱신 → 워치 backlog(역순 수신) 시 ts 역행·신선도 바 stale

AFTER

수집시각(`ts`) 기준 **최신 우선**(역순 샘플은 gap만 보강). 순수 함수 `mergeLatestByWorker` 추출 → 테스트 가능

검증 — `store.test.ts` "backlog 역순 삽입 시 ts 역행하지 않는다(L1)" 케이스 통과.

조치 L2 weather route `workerCount=0` 오기록 차단

BEFORE

`Number(url.searchParams.get("workers"))` — 파라미터 부재 시 `Number(null)===0`이 finite라 `weather_log`에 0 기록

AFTER

raw `null`을 먼저 검사 → 부재 시 `undefined` 기록(의도대로)

5. 테스트 부채 (신규 23건 + 러너)

ID	파일	건수	커버
L4	`schemas/vital-stream.test.ts`	9	수신 스키마 경계값(workerId·ts·hr·spo2·temp·GPS). **no-op이던 `test` 스크립트 실동작화**
L5	`dashboard/lib/severity.test.ts`	8	위험도 판정 경계 — THRESHOLDS 기준(매직넘버 아님) + overallStatus 낙상/SOS
M3	`dashboard/app/api/mock/store.test.ts`	6	reserved 필터 + sticky carry-forward + **L1 ts 역행 가드** + 이벤트 비-sticky + 정렬

인프라: dashboard에 `tsx --test` 러너(+tsx devDep) 추가, 루트 `pnpm test`가 dashboard 포함, analyzers/schemas exports에 `default` 조건 추가(node/tsx resolution). 전체 **38/38 통과**(analyzers 15 · schemas 9 · dashboard 14).

6. 위생 정리

ID	조치
L6/L7/L8	dead code 제거 — `SafetyMonitorLogo` 컴포넌트 · `SEVERITY_TEXT_CLASS` · `persistedByWorker`(+ 전용 `countByWorker` prepared stmt)
L17	`db.ts` `persistSiteInfoDaily`의 `.get()` 결과 nullable 처리(강제 캐스트 제거)
L12	`pubspec.yaml` geolocator 중복 platform 핀 제거(umbrella 가 endorsed 로 포함) — 다음 Flutter 빌드 전 flutter pub get 필요
L10/L11	의도된 스캐폴딩 명시 — Flutter MQTT 경로·schemas Worker에 "미연결(발표 후 AWS/백엔드)" 주석
L13~L16	문서 정합 — CLAUDE.md turbo→pnpm 주석 · backend README stale 상태→canonical 포인터 · "4 worker"→5 · CLAUDE.md 코드트리 미존재 경로 명시

7. 검증 & 빌드 사고 처리

⚠️ **검증 중 사고와 복구.** 추가 검증으로 `next build`를 실행했으나, 이 프로젝트는 `next build`를 쓰지 않고(AWS 배포 보류 → `next dev`만 운용) 구동 중인 dev 서버와 `.next` 디렉터리를 공유해 충돌, dev가 HTTP 500으로 오염됐다. **원인은 코드가 아닌 dev+build 동시 실행 artifact**(CLAUDE.md에 기록된 ".next stale chunk 500" 패턴). 조치: 멈춘 build 종료 → `.next` 삭제 → dev 동일 바인딩(127.0.0.1:3000)으로 재기동 → `GET / 200` 회복(cloudflared 터널·URL 보존). 이후 `next build`는 비표준이라 제거. **이로 인한 코드 변경 0.**

검증 항목	결과
전체 typecheck (`pnpm typecheck`)	exit 0 — schemas·analyzers·dashboard
단위 테스트 (`pnpm test`)	38/38 pass (15+9+14), fail 0
dev 런타임 `GET /`	HTTP 200 (1.45s 컴파일)
dev 런타임 `GET /api/mock/vital`	200 · `piiRedacted: true` (M1 live)

8. 커밋 내역 (main, ahead 58 · push 보류)

SHA	메시지
`648d942`	fix(security): 공개 터널 PII/인증 차단 (audit A: M1·M2·L3)
`fcc74d0`	refactor(dashboard): THRESHOLDS 단일 source + 타입 강화 + 정확성/dead code
`417cd09`	test: dashboard/schemas 단위 테스트 추가 + 러너 (M3·L4·L5)

`c09c76e`	chore(worker-phone, schemas): 위생 정리 (L10·L11·L12)
`f981265`	docs: 종합 audit 기록·트래커 + 문서 정합 (세션17 + L13~L16)

9. 남은 사용자 액션 (코드 외, 발표 전 권장)

1. **`.env.local`의 `ADMIN_PASSWORD` 회전** — 기존 `safety2026`은 audit으로 공개됨. 강한 값으로 교체(미설정 시 fail-closed라 관리자 메뉴 인증 거부).
2. **데모 SOS 보호자 연락/지도가 필요하면 `.env.local`에 `MOCK_VITAL_EXPOSE_PII=true`** — 기본값(미설정)에서는 PII가 가려져 SOS 모달의 보호자 전화·GPS 지도가 빈 상태가 된다. 신뢰된 로컬/터널 데모에서만 활성.
3. **Flutter 재빌드 전 `flutter pub get`** — geolocator platform 핀 제거 반영(lock 갱신).

10. 결론

선행 Audit 발견 **23건 전부 조치**했고, 전체 typecheck·단위 테스트 38건·dev 런타임으로 검증을 완료했다. 보안 측면에서 **공개 터널 데모의 PII·관리자 인증 표면이 fail-safe로 닫혔고**(M1·M2·L3), 코드 품질 측면에서 **임계 단일 source가 복구**(M5)되고 **타입 안전성이 모노레포 기준에 정렬**(M4)됐다. 핵심 수신 경로와 위험도 판정에 회귀 방지 테스트가 도입돼, 발표 후 실서비스화 트랙으로의 진입 기반이 마련됐다.
